

Information Security and Access Management Policy

Controlled Enterprise RAG Benchmark v1. Text-based single-column source document.

1. Purpose and Scope

This Information Security and Access Management Policy defines baseline controls for Meridian Retail Group systems, user accounts, privileged access, authentication, endpoint devices, incident reporting, and data classification. The policy applies to employees, contractors, service accounts, vendors, and administrators with access to company systems.

The policy covers production systems, corporate applications, cloud consoles, source code repositories, analytics workspaces, customer support tools, and laptops used to access company data.

2. Password and MFA Requirements

All user accounts must use unique passwords that are not reused across personal or external services. Password managers approved by Corporate IT may be used to generate and store credentials. Passwords must never be sent through chat, email, ticket comments, or shared documents.

Multi-factor authentication is required for email, VPN, source code systems, production dashboards, cloud administration consoles, and finance systems. Hardware security keys are required for privileged administrators and recommended for engineering leads.

Account Type	Minimum Length	Rotation	MFA Requirement	Lockout Rule
Standard user	14 characters	180 days	Authenticator app or security key	10 failed attempts
Privileged admin	18 characters	90 days	Hardware security key	5 failed attempts
Service account	32 characters	365 days	Vault-managed secret	Alert on first failed use
Break-glass account	20 characters	After every use	Hardware key + CISO approval	3 failed attempts

3. Account Lockout and Recovery

Accounts that hit the lockout threshold remain locked for 30 minutes or until Corporate IT verifies the user's identity. Privileged administrator lockouts must be reviewed by the Security Operations Center before access is restored.

Suspected credential compromise requires immediate password reset, active session revocation, token rotation, and manager notification.

4. Access Request and Approval Process

Access requests must be submitted through the Access Portal with business justification, system name, requested role, data classification, duration, and approving manager. Access to confidential or restricted systems requires system owner approval in addition to manager approval.

Temporary access must include an expiration date. The maximum duration for temporary elevated access is 14 calendar days unless the Chief Information Security Officer approves an extension.

Access Category	Approver	Maximum Duration	Review Evidence
Standard application access	Manager	Indefinite while role remains valid	Access Portal request
Confidential data access	Manager + System Owner	180 days	Business justification
Production support access	Engineering Manager + System Owner	30 days	Incident or support ticket

Access Category	Approver	Maximum Duration	Review Evidence
Privileged administrator	Director + Security	90 days	Admin access review record
Emergency break-glass	CISO or delegate	8 hours	Incident ticket and post-use review

5. Role-Based and Privileged Access

Role-based access control must grant the minimum permissions necessary for the employee's job function. Shared accounts are prohibited except for approved service accounts managed through the company vault.

Privileged sessions must be logged. Administrator access to production databases requires a linked change ticket or incident ticket. Direct database changes outside approved maintenance windows require director approval.

6. Device and Endpoint Security Requirements

Devices used to access company systems must run supported operating systems, full-disk encryption, endpoint detection and response, automatic screen lock, and current security patches. Laptops missing critical patches for more than 7 days are blocked from VPN access.

Personal devices may access email only through managed mobile application controls. Personal laptops may not access source code, production systems, restricted data, or administrative cloud consoles.

Control	Required Setting	Compliance Deadline	Escalation
Full-disk encryption	Enabled on all laptops	Before device assignment	IT manager
Critical patching	Installed within 7 days	7 days after release	Security Operations
Screen lock	10 minutes inactivity	Immediate	Corporate IT
Endpoint detection	Agent healthy and reporting	24 hours after enrollment	Security Operations

7. Incident Reporting

Employees must report suspected phishing, lost devices, unauthorized access, accidental data sharing, malware alerts, and suspicious authentication prompts to Security Operations within 1 hour of discovery.

Incidents involving restricted data, production credentials, or cross-tenant exposure are treated as high severity until triage proves otherwise. Evidence such as audit logs, suspicious emails, screenshots, and ticket history must be preserved.

8. Access Reviews and Data Classification

Managers review standard application access quarterly. System owners review confidential data access every 90 days. Security reviews privileged administrator access monthly and break-glass account usage after every use.

Company data is classified as Public, Internal, Confidential, or Restricted. Restricted data includes government identifiers, payment card data, authentication secrets, production credentials, and customer personal data requiring regulatory protection.

9. Exceptions

Security exceptions must document the control gap, affected system, compensating control, business reason, risk owner, and expiration date. Exceptions for restricted data systems may not exceed 30 days without CISO approval.

Expired exceptions automatically return to non-compliant status and must be remediated or reapproved before access continues.